

Tefoma Procurement

End-to-End Smoke Test Report

Production environment · Full procurement lifecycle

Date of test	19 July 2026	Test run ID	SMOKE-1784458385767
Target system	tefomaprocurement-api.vercel.app (LIVE)	Auth method	OTP login (email 2FA)
Tester	Automated API smoke suite	Workflow paths	Competitive + Waiver (single-source)

62	46	14	2
TOTAL STEPS	PASSED	FAILED	SKIPPED

VERDICT: Core procurement lifecycle is FUNCTIONAL end-to-end

Requisition !' HOD approval !' stores !' procurement !' RFQ !' quotation !' PO (HOD+Finance approval) !' supplier acknowledgement !' goods receipt (GRV) !' invoice !' payment all completed successfully via the compliant sourcing path. 4 gaps were identified (1 security, 3 functional/robustness) — see Findings.

This report documents a live smoke test executed against the production API on 19 July 2026. Test accounts were created for every role, driven through the complete workflow, then removed. All findings below are real observations from the running system.

Key Findings & Gaps

Ranked by severity. Each was observed directly during the live run against production.

1. Login OTP is exposed in the API response (2FA bypass)

HIGH

The production login endpoint returns the one-time passcode in the JSON response body (field "debugOtp"). Confirmed live: POST /api/auth/login returns the OTP to any caller. This defeats the purpose of email-based two-factor authentication — an attacker who knows only a password (or is testing credentials) receives the OTP directly and can complete login without access to the victim's email.

Root cause: shouldExposeOtpInResponse() in otp.service.ts defaults to TRUE unless OTP_EXPOSE_IN_RESPONSE is explicitly "false". The production Vercel environment has no OTP_EXPOSE_IN_RESPONSE variable set, so the default (exposed) is active.

Recommended fix: Set OTP_EXPOSE_IN_RESPONSE=false in the production Vercel environment and redeploy the API. Consider inverting the default so it is opt-IN for local testing only.

2. Procurement Head cannot approve a quotation waiver

MEDIUM

A user who is head of the Procurement department (role department_head in the Procurement dept) is treated as a "procurement head" with procurement-officer powers across the app — but the waiver endpoint rejected them with "Waiver approval requires COO or Procurement Manager". This blocks the single-source/waiver path for that role.

Root cause: approveQuotationWaiver.controller.ts checks role === "procurement_officer" || coo || admin, but does NOT call isProcurementHead(user), unlike other procurement routes which do honor it.

Recommended fix: Add isProcurementHead(req.user) to the authorization check in approveQuotationWaiver.controller.ts, consistent with procurement.route.ts.

3. Invalid waiverType causes a 500 instead of a 400

MEDIUM

Submitting a waiver with a waiverType not in the schema enum (e.g. "sole_source" vs the correct "single_source") returns a raw HTTP 500 "Server error" from an uncaught Mongoose validation error, rather than a clean 400 with a helpful message. Any client sending a slightly-off enum value gets an opaque server error.

Root cause: The RFQ.model quotationWaiver.waiverType enum is [service_agreement, single_source, approved_contract, no_quotes, unique_product, coo_directed, custom_manufacture, coo_instruction, other]. The controller passes the value straight to save() without validating against the enum, so a bad value throws a ValidationError caught only by the generic 500 handler.

Recommended fix: Validate waiverType against the allowed list in the controller and return 400 on mismatch. Also align the enum values used across UI/docs (note the "single_source" spelling).

4. Three-way match flags a variance on a correct, VAT-inclusive PO

MEDIUM

A correct invoice was flagged "submitted with variances — finance review required" even though quantities and unit prices exactly matched the PO. The PO total (1288) includes VAT while the invoice line totals were pre-VAT (1120), so the total-level tolerance check fails and forces every VAT-inclusive PO into manual finance review.

Root cause: threeWayMatch.service.ts compares invoicedTotal against receivedValue and poTotal (both VAT-inclusive) using a 2% tolerance, but invoice line totalPrice is VAT-exclusive. The VAT component is never reconciled, so any PO with VAT will always exceed tolerance.

Recommended fix: Compare like-for-like: match invoice line totals against PO line totals excluding VAT, and reconcile VAT separately, or add the invoice vatAmount before the total-tolerance comparison.

5. Test-only seed accounts do not exist in production

LOW

Of the documented seed accounts, only admin@fossilzim.com works in production; all other role accounts (procurement, HOD, finance, COO, stores, end-user) returned 401. This is expected for a real deployment but means the shipped smoke/E2E scripts (which assume seed logins) cannot run against production without first creating accounts.

Root cause: Production DB holds real data (200+ suppliers, 13 departments, 12 sites), not the local seed set the scripts target.

Recommended fix: No action required for production. For repeatable prod smoke tests, maintain a small set of dedicated, clearly-tagged test accounts, or run the suite against a staging/seeded environment.

Scope & Methodology

What was tested

The complete procurement lifecycle exercised through the live production REST API, covering all eight user roles: end user, department head, procurement (head), stores officer, finance, COO, admin, and supplier.

- Supplier self-registration and procurement KYS activation
- Requisition creation, submission, and Department-Head approval (same-department rule enforced)
- Stores availability review and forwarding to procurement
- RFQ creation/publishing and supplier visibility of invited RFQs
- Quotation submission by supplier
- Competitive-sourcing control (minimum 3 quotations) and the single-source waiver path
- HOD selection !' Procurement Manager authorization !' acceptance of the winning quotation
- Purchase Order creation and the HOD !' Finance (!' COO for "e USD 5k) approval chain
- Supplier PO acknowledgement
- Goods receipt (GRV) and acceptance into inventory
- Supplier invoice submission, three-way match, finance approval, and payment

How it was run

An automated Node script authenticated each role via the real OTP login flow, then issued live API calls in workflow order, recording the HTTP status and message of every step. Two sourcing paths were run: (1) a competitive path with a single invited supplier — which correctly hit the 3-quotation control — and (2) a waiver path that satisfied the control and proceeded to completion.

Data safety & traceability

Every record created carries the marker SMOKE-1784458385767 in its name/description, and all created IDs were written to a manifest for exhaustive cleanup. Seven test users were created and driven through the flow.

Test Data Cleanup

All 7 smoke user accounts were deleted (soft-delete) and verified.

Confirmed: deleted accounts return 401 on login and no longer appear active in the admin user list.

Honest cleanup caveat

The application exposes DELETE only for users (a soft-delete that sets isDeleted=true). It has NO delete endpoint for transactional records — requisitions, RFQs, quotations, POs, deliveries, invoices, or payments can only be cancelled, not removed. The following smoke records therefore REMAIN in the production database. They are all tagged SMOKE-1784458385767 and are in terminal states. Remove them via a direct database operation if you want a fully clean production dataset.

- 4 Requisitions left in production (tagged, terminal state)
- 4 RFQs left in production (tagged, terminal state)
- 4 Quotations left in production (tagged, terminal state)
- 1 Purchase Orders left in production (tagged, terminal state)
- 1 Deliveries (GRV) left in production (tagged, terminal state)
- 1 Invoices left in production (tagged, terminal state)
- 1 Payments left in production (tagged, terminal state)

Full record IDs are preserved in the run manifest that accompanies this test.

Flow 1 — Competitive Sourcing Path (single supplier)

Result: 26 passed, 13 failed, 1 skipped of 40 steps.

PHASE	STEP	RESULT
AUTH	Admin login + OTP verify	PASS
SETUP	Found working + procurement departments	PASS
USERS	Create end_user (smoke.enduser.1784458385767@smoke.test)	PASS
USERS	Create department_head (smoke.hod.1784458385767@smoke.test)	PASS
USERS	Create department_head (smoke.prothead.1784458385767@smoke.test)	PASS
USERS	Create finance (smoke.finance.1784458385767@smoke.test)	PASS
USERS	Create coo (smoke.coo.1784458385767@smoke.test)	PASS
USERS	Create stores_officer (smoke.stores.1784458385767@smoke.test)	PASS
SUPPLIER	Supplier self-registration	PASS
AUTH	All 7 smoke roles authenticate	PASS
SUPPLIER	Procurement sees pending smoke supplier	PASS
SUPPLIER	Procurement activates supplier (KYS override)	PASS
REQUISITION	End user creates requisition (draft)	PASS
REQUISITION	End user submits requisition	PASS
REQUISITION	HOD approves requisition	PASS
STORES	Stores forwards requisition to procurement	PASS
PROCUREMENT	Procurement accepts requisition	PASS
RFQ	Procurement creates & publishes RFQ	PASS
RFQ	Supplier can see invited RFQ	PASS
QUOTATION	Supplier submits quotation	PASS
RFQ	Procurement closes RFQ	PASS
QUOTATION	HOD selects winning quotation <i>Minimum 3 quotations required or an approved waiver (currently 1)</i>	FAIL
QUOTATION	Procurement authorizes quotation <i>Can only authorize the quotation selected by HOD</i>	FAIL
QUOTATION	Procurement accepts quotation <i>Requires at least 3 quotations or approved waiver (found 1)</i>	FAIL
PO	Procurement creates PO <i>Can only create PO from accepted quotations</i>	FAIL
PO	Procurement submits PO for approval <i>Cast to ObjectId failed for value "undefined" (type string) at path "_id" for model "PurchaseOrder"</i>	FAIL
PO	HOD approves PO <i>Server error</i>	FAIL
PO	Finance approves PO <i>Server error</i>	FAIL
PO	COO approval (PO below 5k threshold) <i>total=0</i>	SKIP
PO	Supplier acknowledges PO <i>Cast to ObjectId failed for value "undefined" (type string) at path "_id" for model "PurchaseOrder"</i>	FAIL
DELIVERY	Stores receives goods (GRV) <i>Purchase order not found</i>	FAIL
DELIVERY	Delivery auto-accepted on receive	FAIL
INVOICE	Supplier submits invoice <i>Purchase order, invoice date, and line items are required</i>	FAIL
INVOICE	Finance approves invoice <i>Server error</i>	FAIL
PAYMENT	Finance records payment <i>All invoices must be approved and not fully paid</i>	FAIL

PHASE	STEP	RESULT
READS	Admin audit logs	PASS
READS	Finance budgets	PASS
READS	Procurement dashboard stats	PASS
READS	End user notifications	PASS
READS	Supplier sees own PO	PASS

Note: steps from "HOD selects winning quotation" onward failed by DESIGN — the system correctly enforced its minimum-3-quotations control. This is a working business rule, not a defect. The waiver path below completes the same downstream stages.

Flow 2 — Waiver Path (single-source, completes to payment)

Result: 20 passed, 1 failed, 1 skipped of 22 steps.

PHASE	STEP	RESULT
AUTH	Re-authenticate all smoke roles	PASS
REQUISITION	End user creates requisition	PASS
REQUISITION	HOD approves requisition	PASS
PROCUREMENT	Procurement accepts requisition	PASS
RFQ	Procurement creates RFQ	PASS
QUOTATION	Supplier submits quotation	PASS
QUOTATION	Waiver by Procurement Head (expected role gap) <i>Waiver approval requires COO or Procurement Manager</i>	FAIL
QUOTATION	Waiver approved (admin fallback)	PASS
QUOTATION	HOD selects quotation (waiver satisfies min-3)	PASS
QUOTATION	Procurement authorizes quotation	PASS
QUOTATION	Procurement accepts quotation	PASS
PO	Procurement creates PO	PASS
PO	Procurement submits PO	PASS
PO	HOD approves PO	PASS
PO	Finance approves PO	PASS
PO	COO approval (below 5k threshold) <i>total=1288</i>	SKIP
PO	Supplier acknowledges PO	PASS
DELIVERY	Stores receives goods (GRV)	PASS
DELIVERY	Delivery auto-accepted on receive	PASS
INVOICE	Supplier submits invoice	PASS
INVOICE	Finance approves invoice	PASS
PAYMENT	Finance records payment	PASS

The one failure is the intentional probe confirming Finding #2 (Procurement Head cannot approve a waiver); the admin fallback then completed the flow through payment.

